

Created by Osareme Davis

1. Cookies

- a. There is currently only one cookie for my browser:

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
theme	default	cs338.jeffondich.com	/	Sat, 25 Jan 2025 21:54:07 GMT	12	false	false	None	Sun, 27 Oct 2024 21:55:55 GMT

- b. Yes. “Value” was updated to “red”, “Size” went to 8, and the expiration date updated to a later time.
- c. In the first HTTP response there is a “set-cookie: theme=default” header. All subsequent HTTP requests from the client include the header “cookie: theme=default”. After changing the theme, the HTTP response includes “set-cookie: theme=red” and, like before, subsequent HTTP requests use “cookie: theme=red”.
- d. Yes, the theme is still red.
- e. The browser includes the header “cookie: theme=red” in its requests based on which cookies are stored locally.
- f. First, the server sends a new “set-cookie” header with the new theme, then the browser changes its cookie and includes the new “cookie” header in its later requests.
- g. It is possible to just change the “value” column for the cookie to the name of the desired theme.
- h. With the intercepted GET request, it is possible to modify the “cookie” header so that the value is the name of the desired theme.
- i. For Firefox on Kali, the file path is: `~/.mozilla/firefox/<profile path>/cookies.sqlite`

2. Cross-site scripting

- a. Moriarty's evil plot:
 - i. Create a post with injected HTML (taking advantage of the mixture of data and control characters in HTML)
 - ii. When a user clicks on the post, the HTML is rendered naively, without sanitation
- b. An attack could retrieve a user's account information upon clicking on the post, then send that information to a server owned by the attacker.
- c. Another attack could redirect the user to another website which automatically attempts to download the file. To disguise the malicious nature of the file, the post could include text like "free Robux" to lower the user's guard and trick them into accepting the download.
- d. The forum should sanitize the user inputs by escaping/encoding special HTML characters. Another mitigation is disabling the ability to run scripts altogether, but this would limit site functionality.